

Auditoria de Segurança — Varredura Estática de Padrões OWASP

Varredura estática executada sobre **16 arquivos de código do projeto real** (orchestrator.py, agents.json, microserviço Devin, prompts). O resultado abaixo lista **casamentos de padrão** (nomes de variáveis e chaves), não vulnerabilidades confirmadas.

Padrão verificado	Ocorrências	Leitura
api_key / secret / token / password	120	Nomes de campo/variável. 19 em agents.json (metadados). Nenhum valor secreto real exposto.
eval() / exec()	0	Ausente
os.system()	0	Ausente
subprocess shell=True	0	Ausente
pickle.loads()	0	Ausente
yaml.load()	0	Ausente

Leitura correta do número 120

As 120 ocorrências são **matches de texto** da expressão regular sobre nomes como api_key, secret, token e password. Elas indicam pontos de **revisão**, não falhas exploráveis. Este documento não afirma 'zero vulnerabilidades' nem '120 vulnerabilidades': afirma 120 pontos a revisar e 0 usos dos construtores mais perigosos.

Recomendações

- Migrar segredos para cofre com rotação automática.
- Manter eval/exec/shell=True proibidos no CI.
- Rodar a varredura a cada release e versionar o relatório.

Escopo: análise estática de padrões (grep/SAST básico). Não inclui teste dinâmico, pentest ou análise de dependências.